

Overview.

- SignUp & Singin Workflow.
- Bcrypt Password Encoder
- Token.

Client

Server

POST
/SignUp(email, password)
← Success.

/login(email, password)
← token axyqm12|xy

axyqm12|xy
/admin (↓)
←

users

id	email	password	----
101	✓	abc123 ✓	—

tokens

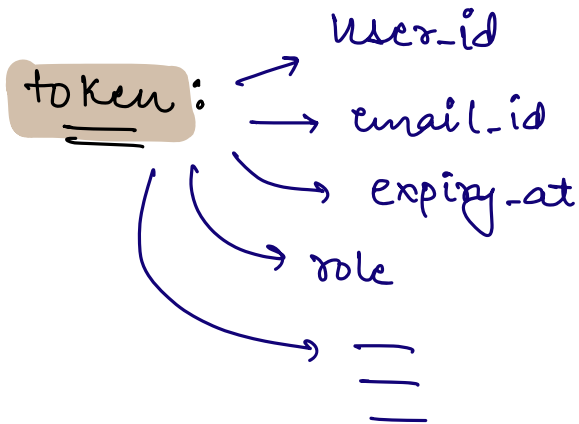
id	userid	value	Expires
1095	101	axyqm12 xy	27 th July - 6:55pm.

→ DB Call.

JWT

↳ Self-Validating Tokens.

JWT can be verified without making a DB call.



 Risk

```
{
  "id" : 1234
  "exp" : _____
  "email" : "deepak@gmail.com"
  "role" : _____
  _____ : _____
  _____ : _____
  _____ : _____
}
```

JWT :

A · B · C → Signature.
 ↓
 Payload.

Encryption
Algo.

```
{  
  "id" : 1234  
  "exp" : _____  
  "email" : "deepak@gmail.com"  
  "role" : _____  
  _____ : _____  
  _____ : _____  
  _____ : _____  
}
```

Base64 Encoding
↓

Encryption | Decryption.

Original
Data

+ Encryption
Algo

+ Secret
key

⇒ Decrypted
Data.

↑

Secret
key

+ Encryption
Algo

←